ACTIVIDAD 09 · CNO IV

File Path Traversal: Secuencias de traversal eliminadas de forma no recursiva

Reporte técnico de explotación — PortSwigger Web Security Academy

portswigger.net/web-security/file-path-traversal/lab-sequences-stripped-non-recursively

Alumno: Jorge Abraham Castelo Curioca

Materia: CNO IV

Docente: Mtro. Servando López Contreras

Entrega: Segundo Parcial

Documento: Path Traversal 3 Actividad 9.pdf

1 Ficha Técnica del Laboratorio

NOMBRE DEL LABORATORIO

File path traversal, traversal sequences stripped non-recursively

NIVEL

Practitioner PORTSWIGGER ACADEMY

TIPO DE EXPLOTACIÓN

File Path Traversal / Directory Traversal (secuencias anidadas)

OBJETIVO DEL LABORATORIO

Evadir el filtro de saneamiento de la aplicación para recuperar el contenido del archivo de sistema `/etc/passwd`.

2 Explicación Técnica de la Vulnerabilidad

La aplicación muestra imágenes de producto a partir del parámetro `filename`, y como mecanismo de defensa elimina las secuencias de traversal `../` que detecta en el valor recibido. El problema es que esta eliminación se hace de forma **no recursiva**: el filtro recorre la cadena una sola vez y quita cada ocurrencia de `../`, pero no vuelve a revisar el resultado después de hacerlo. Esto permite construir una secuencia anidada como `....//`, de modo que al quitarle la subcadena `../` que queda "escondida" en el centro, lo que sobra se reconstruye exactamente en un salto de directorio válido (`../`). Como el servidor no vuelve a aplicar el filtro sobre el resultado, el salto se procesa con normalidad y permite escapar del directorio de imágenes hasta llegar a archivos sensibles del sistema operativo.

3 Procedimiento Paso a Paso

1 Interceptación inicial con Burp Suite

Se inició el laboratorio y se configuró el navegador para que el tráfico pasara por Burp Suite. Al navegar por la tienda, el proxy capturó las peticiones `GET` que la aplicación hace al endpoint `/image?filename=...` para cargar cada imagen de producto, lo que confirma que el parámetro `filename` es la entrada que controla qué archivo se sirve.

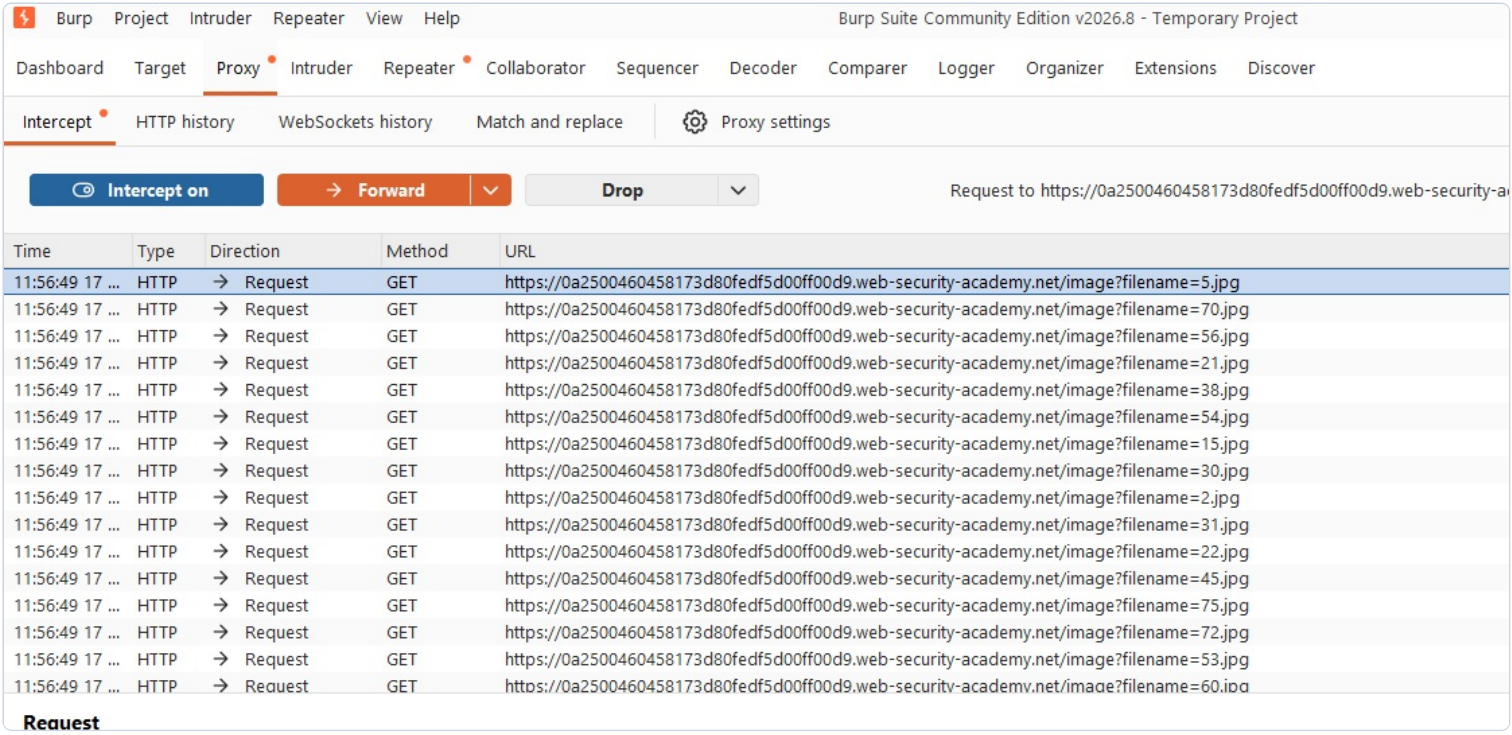


Fig. 1 — Pestaña Proxy / Intercept de Burp Suite mostrando las peticiones GET a /image?filename=<n>.jpg generadas al cargar el catálogo de productos.

2 Análisis de la consulta base

Se envió al Repeater una petición normal de imagen (`filename=5.jpg`) para observar su comportamiento de referencia: el servidor responde `200 OK` con `Content-Type: image/jpeg` y el contenido binario de la imagen solicitada. Esto confirma que el archivo se construye en el servidor a partir del valor recibido en `filename`, por lo que es un punto de entrada candidato para path traversal.

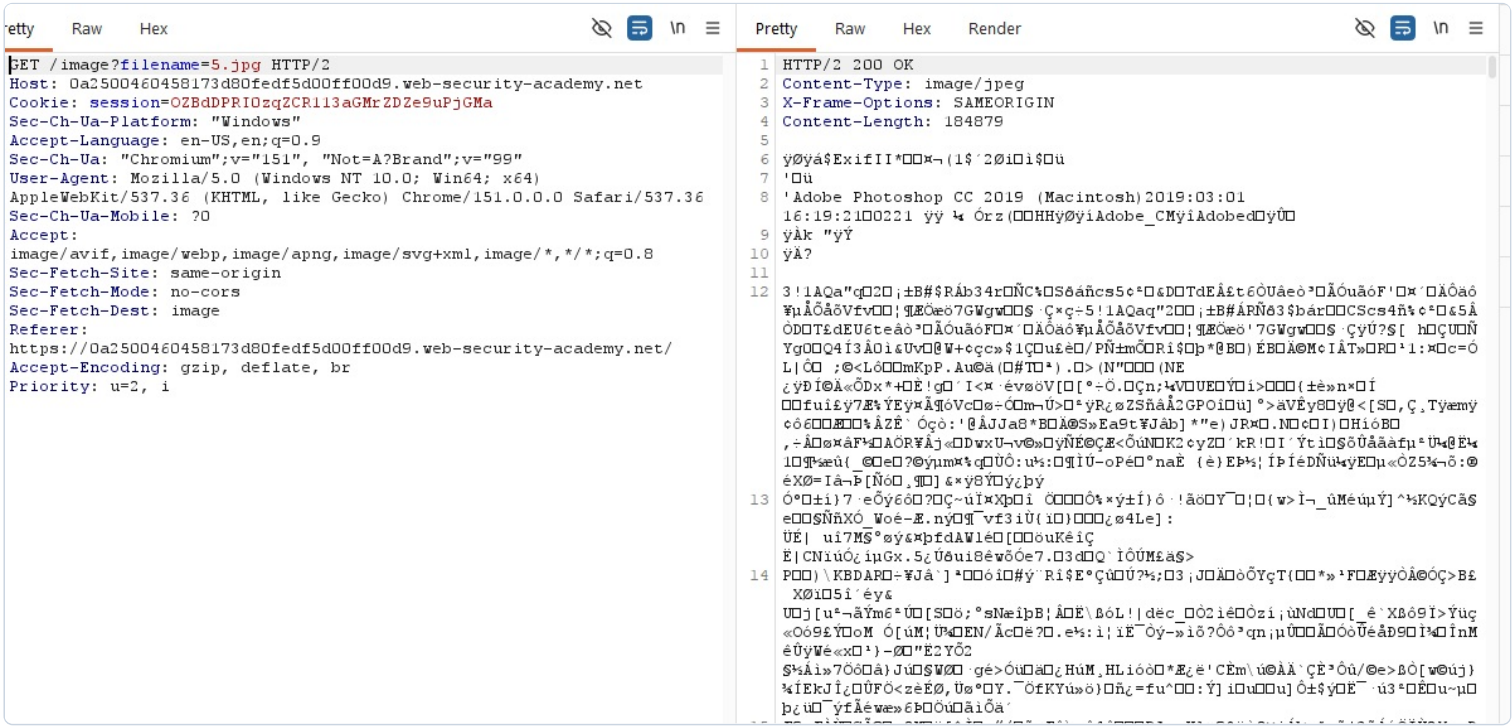


Fig. 2 — Repeater: request con filename=5.jpg y respuesta 200 OK devolviendo la imagen en formato binario (comportamiento esperado, sin manipulación).

3 Construcción y envío del payload

Dado que el laboratorio elimina secuencias `../` de forma literal y no recursiva, se modificó el parámetro `filename` en el Repeater usando una secuencia anidada que sobrevive a una sola pasada de filtrado:

```
filename=....//....//....//etc/passwd
```

Se envió la petición modificada desde el Repeater hacia el servidor para verificar si el filtro era evadido.

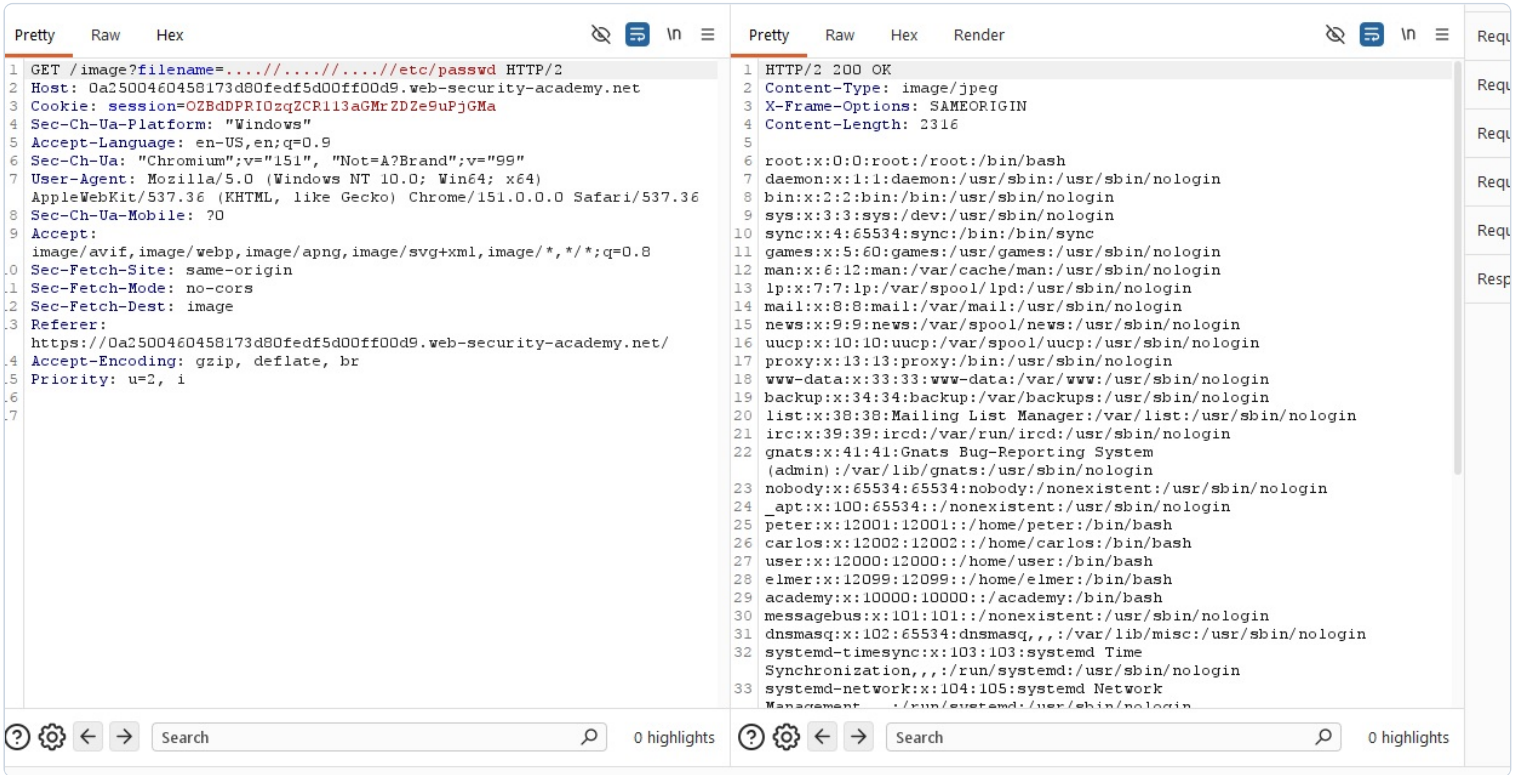


Fig. 3 — Repeater: request con el payload ....//....//....//etc/passwd y respuesta 200 OK devolviendo en texto plano el contenido completo de /etc/passwd (usuarios root, daemon, peter, carlos, user, elmer, academy, entre otros).

✓ Confirmación de éxito

El servidor devolvió el listado completo de `/etc/passwd` sin aplicar ningún tipo de bloqueo adicional sobre la secuencia anidada, por lo que la vulneración fue exitosa y la plataforma marcó el laboratorio como resuelto.



Fig. 4 — Insignia "LAB Solved" otorgada por PortSwigger Academy al confirmarse la explotación.

4 Explicación del Payload y Mitigación

Explicación del payload

```
....//....//....//etc/passwd
```

A diferencia del bypass por ruta absoluta usado en la actividad anterior, aquí el servidor sí intenta bloquear `../`, pero lo hace eliminando únicamente la primera coincidencia que encuentra en cada posición. En la secuencia `....//`, al quitar la subcadena interna `../` quedan los caracteres restantes `../`, que es exactamente un salto de directorio válido. Al repetir el bloque tres veces (`....//....//....//`) se obtienen tres saltos reales hacia arriba en el árbol de directorios, suficientes para salir de la carpeta de imágenes y llegar a la raíz del sistema de archivos, desde donde se referencia `etc/passwd` directamente.

Mitigación recomendada

- Eliminar las secuencias de traversal de forma **recursiva** (o, mejor, no depender de un filtro de "lista negra" para esto).
- Validar la entrada contra una **lista blanca** de nombres de archivo permitidos en lugar de intentar sanear la cadena recibida.
- Usar las APIs del sistema operativo para **canonicalizar** la ruta resultante y verificar que siga ubicada dentro del directorio base esperado antes de abrir el archivo.
- Ejecutar el proceso que sirve los archivos con el **mínimo privilegio** necesario, para limitar el impacto si el filtro vuelve a fallar.